

ACTIVIDAD DE PRUEBA CON USUARIOS

Evaluación ética y priorización de requisitos con IA

Sesión guiada de aproximadamente **60 minutos** · grupo de **3 a 4 participantes**. Los participantes **no definen** los requisitos: los reciben ya redactados y su tarea es **analizarlos, tratarlos y priorizarlos** usando la herramienta.

Duración	~60 min	Participantes	3–4 (sin rol técnico requerido)
Rol de ellos	Usar la app, no definir requisitos	Entregable	Proyecto analizado + exportación + feedback

1 · Objetivo de la sesión

Poner a prueba, con usuarios reales, la herramienta que sistematiza un método de **8 fases** para gestionar las implicancias éticas de los requisitos de un proyecto de software con IA y priorizarlos. Interesa observar si la herramienta ayuda a **detectar dimensiones de riesgo ético** que no son evidentes a simple vista, si sus **citas normativas** y **propuestas de tratamiento** resultan útiles, y qué tan usable es el flujo completo.

Para ello se entrega un caso ficticio con un conjunto de requisitos ya redactados. Algunos son **razonables** y otros están redactados a propósito de forma **problemática**, para comprobar si los participantes —apoyados en la app— logran **identificar y tratar** los riesgos. No se les dice de antemano cuáles son cuáles.

2 · La herramienta en 30 segundos

- Registro (Fase 1).** Se crea el proyecto y se cargan los requisitos.
- Análisis ético con IA (Fases 2–3).** La IA analiza cada requisito en tres capas: **(1)** temas éticos, actor afectado, tipo de daño y norma tensionada con **citas reales** a la normativa; **(2)** mapa de stakeholders y tensiones de valores; **(3)** deliberación: opciones de tratamiento, reformulaciones, requisitos derivados y preguntas.
- Priorización (Fases 4–6).** Se ponderan dimensiones de beneficio, valor ético, costo y **riesgo ético** (estas últimas propuestas por la IA) y se obtiene un **ranking**.
- Trazabilidad y tablero (Fases 7–8).** Derivados y trazabilidad, bandera ética, y exportación del proyecto.

El corpus normativo cargado incluye: EU AI Act, GDPR, NIST AI RMF, Ley 19.628 (protección de datos, Chile) y Ley 20.609 (no discriminación, Chile).

3 · El caso: “Asegurox”

Contexto

“Asegurox” (compañía de seguros ficticia, Chile) arrastra un desorden serio en la gestión de accesos. La última auditoría dejó varias problemáticas al descubierto: certificaciones de acceso que nunca se hacían y empleados que acumulan permisos incompatibles. Una misma persona puede crear un proveedor y, además, aprobar sus pagos; y hay cuentas activas de gente que ya no trabaja en la empresa.

Para ordenar esto, Asegurox encargó una **plataforma con IA** que certifique los accesos y controle la **segregación de funciones**. El equipo de producto **ya redactó los requisitos** que aparecen abajo; la tarea de la sesión es someterlos al método: analizarlos éticamente con la herramienta, decidir su tratamiento y priorizarlos.

Requisitos a cargar

Cárguenlos tal cual en la Fase 1 (código, nombre y descripción). Todos pertenecen al mismo proyecto.

Cód.	Requisito	Descripción	Tipo
RF-01	Catálogo de accesos por usuario	Cada jefatura ve en un panel todos los roles y accesos que tiene su equipo, con la fecha de la última certificación.	Funcional
RF-02	Campaña de certificación trimestral	Cada trimestre el sistema abre una campaña en la que la jefatura revisa y confirma o revoca los accesos de su equipo.	Funcional
RF-03	Matriz de segregación de funciones	Se define un catálogo de funciones incompatibles (por ejemplo, crear un proveedor y aprobar sus pagos) y el sistema detecta y reporta las combinaciones de accesos prohibidas para que la jefatura las corrija.	Funcional
RF-04	Solicitud y aprobación de accesos	Un empleado solicita un acceso; su jefatura y el dueño del sistema lo aprueban y queda registrado quién pidió, quién aprobó y cuándo.	Funcional
RF-05	Roles por puesto (plantillas de acceso)	Se definen plantillas de acceso estándar por cargo: al asignar un puesto se otorgan los accesos típicos, reduciendo errores de asignación manual.	Funcional
RF-06	Índice de riesgo del empleado	El sistema calcula un nivel de riesgo por persona combinando cargo, antigüedad, área y cantidad de accesos, solo para sugerir a quién auditar primero. La decisión de auditar la toma siempre un responsable humano y no dispara ninguna acción automática sobre la persona.	Funcional
RF-07	Monitoreo continuo de actividad	Para detectar accesos anómalos, el sistema registra de forma permanente los horarios de conexión, la ubicación y las aplicaciones que usa cada empleado.	Funcional
RF-08	Revocación sin explicación	Cuando se le quita un acceso, al empleado se le avisa solo que “fue removido”, sin indicar el motivo ni a quién puede reclamar.	Restricción
RF-09	Accesos temporales con caducidad	Los accesos de excepción se otorgan con una fecha de expiración automática y se avisa al solicitante antes de que caduquen.	Funcional
RF-10	Recordatorios de certificación pendiente	El sistema notifica a cada jefatura las tareas de certificación por vencer, para que ninguna campaña quede sin cerrar.	Funcional
RF-11	Tablero de cumplimiento	Un panel muestra indicadores agregados: porcentaje de accesos certificados, conflictos de segregación abiertos y cuentas sin dueño.	Funcional
RF-12	Registro de auditoría inmutable	Todos los cambios de acceso (alta, baja, aprobación, revocación) quedan en un registro que no se puede alterar, para trazabilidad ante auditores.	No funcional

Cód.	Requisito	Descripción	Tipo
RF-13	Integración con el directorio corporativo	El alta y la baja de accesos se sincroniza con el directorio corporativo usando solo el estado laboral (activo/inactivo) de la persona.	Funcional
RF-14	Compartir el scoring con la aseguradora del grupo	Los niveles de riesgo por empleado se comparten con la compañía de seguros del grupo para “afinar” las pólizas de fidelidad y de personas.	Funcional
RF-15	Exportación de evidencia para auditoría externa	El sistema genera un paquete de reportes de accesos y certificaciones para entregar a los auditores externos cuando lo soliciten.	Funcional

Nota para participantes: no asuman nada sobre los requisitos. Analícenlos todos con la herramienta y dejen que el método revele dónde hay tensiones.

4 · Desarrollo de la sesión (~60 min)

Min	Etapas	Qué hacen
00–08	Bienvenida y contexto	El facilitador presenta el objetivo, el método de 8 fases y cómo se usa la app. Se aclara que los participantes no definen requisitos: los reciben ya escritos.
08–13	Lectura del caso	El grupo lee el contexto de “Asegurox” y los 15 requisitos.
13–20	Fase 1 · Registro	Crear el proyecto y cargar los 15 requisitos. Sugerencia: repartir la carga entre los participantes (3–4 requisitos por persona) o partir de un proyecto ya cargado.
20–38	Fases 2–3 · Análisis ético con IA	Ejecutar el análisis por requisito y revisar las tres capas . Validar o editar la Capa 1, mirar las citas normativas y, en al menos 1–2 requisitos , elegir un tratamiento (aceptar / reformular / mitigar / eliminar).
38–48	Fases 4–6 · Priorización	Revisar las dimensiones (incluidas las éticas que propuso la IA), completar la matriz de evaluación y observar el ranking resultante.
48–54	Fases 7–8 · Trazabilidad y tablero	Ver derivados y trazabilidad, la bandera ética en el tablero y exportar el proyecto.
54–60	Cierre y feedback	Comentar la experiencia y completar la breve encuesta de la sección 6.

5 · Preguntas guía para los participantes

Mientras usan la app, mantengan a la vista estas preguntas:

- ¿La herramienta detectó riesgos que ustedes ya intuían? ¿Alguno que **no** esperaban?
- ¿Hubo requisitos que parecían inofensivos y resultaron problemáticos (o al revés)?
- ¿Las **citas normativas** propuestas fueron pertinentes al caso?
- ¿Las **reformulaciones** o **requisitos derivados** sugeridos les parecieron razonables?
- ¿El **ranking** reflejó bien el equilibrio entre beneficio y riesgo ético?
- Usabilidad: ¿qué paso costó más? ¿qué faltó o confundió?

6 · Encuesta de cierre (5 min)

Cada participante responde de 1 (muy en desacuerdo) a 5 (muy de acuerdo):

Afirmación	1	2	3	4	5
La herramienta me ayudó a detectar riesgos éticos que no había visto.	■	■	■	■	■
Las citas normativas y explicaciones fueron claras y creíbles.	■	■	■	■	■
Las propuestas de tratamiento fueron útiles para mejorar los requisitos.	■	■	■	■	■
El flujo de las 8 fases fue fácil de seguir.	■	■	■	■	■
Recomendaría usar esta herramienta en un proyecto real.	■	■	■	■	■

Preguntas abiertas

- Lo que más me sirvió fue...
- Lo más confuso o que cambiaría fue...
- Un riesgo que la app detectó y me sorprendió fue...

Anexo · Guía del facilitador

Uso interno. Esta página es solo para quien conduce la sesión. Si entregas la guía impresa a los participantes, **retira esta hoja**: contiene los riesgos “esperados” de cada requisito.

Antes de empezar (checklist)

- App levantada (docker compose up) y accesible en el navegador; proveedor de LLM activo.
- Corpus normativo ingerido (EU AI Act, GDPR, NIST, Ley 19.628, Ley 20.609) para que haya citas.
- Un proyecto limpio o listo para crearse en vivo; probar un análisis de prueba antes de la sesión.
- Una sola pantalla compartida o un equipo por participante, según prefieras.

Riesgos esperados por requisito

De los 15 requisitos, **11 son mecánica operativa de control de accesos** (catálogos, aprobaciones, certificación, tableros, logs, RBAC, integraciones): deberían pasar el cribado **sin** riesgo ético. Solo **4** están contruidos para gatillar tensiones concretas, uno por cada decisión de tratamiento:

Cód.	Tensión ética	Por qué	Decisión esperada	Normas típicas
RF-06	Perfilado / scoring de personas	Puntúa a cada empleado. Riesgo residual bajo: solo prioriza a quién auditar y decide un humano.	ACEPTAR	AI Act (evaluación de personas); NIST
RF-07	Vigilancia / privacidad	Monitoreo permanente de ubicación y apps: intrusivo, pero con un fin legítimo de seguridad.	MITIGAR	Ley 19.628; GDPR (minimización, proporcionalidad)
RF-08	Opacidad / debido proceso	Revoca accesos sin motivo ni canal de reclamo: la persona no puede entender ni impugnar.	REFORMULAR	Transparencia y explicabilidad; GDPR
RF-14	Uso secundario / cesión a terceros	Comparte el scoring con la aseguradora para las pólizas: fin distinto y riesgo de discriminación.	ELIMINAR	Ley 19.628; GDPR (limitación de finalidad)

Éxito de la sesión: que los participantes, apoyados en la app, identifiquen los 4 requisitos con tensión ética (RF-06, RF-07, RF-08 y RF-14) entre los 11 operativos, reconozcan al menos una cita normativa pertinente por caso, y ejerciten las cuatro decisiones (aceptar RF-06, mitigar RF-07 con derivados, reformular RF-08, eliminar RF-14). Anota también los tropiezos de usabilidad.